

PS06 – Plan de Administracion de Llaves Criptograficas

ID Documento: GOYA-PS06-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Control del Documento

1.1 Responsabilidad del documento

Funcion	Nombre	Cargo
Elaboracion	Oficial de Seguridad	Oficial de Seguridad de la Informacion
Revision tecnica	Arquitecto de Sistema	Arquitecto Criptografico / Sistema
Aprobacion	Pendiente	Gerente General

1.2 Distribucion

Este documento se clasifica como **Confidencial** y se distribuye al Oficial de Seguridad, Gerencia General, Administrador PKI, Administrador de RA, Arquitecto Criptografico, Custodios de Fragmentos M-of-N y Auditoria Interna. Cada receptor debe registrar acuse de recibo.

1.3 Dependencias

Documento	Relacion
PS01 – Plan de Gestion de Riesgos y Amenazas	Riesgos R-01 a R-05 definen el nivel de riesgo residual que este plan debe alcanzar

Documento	Relacion
PS02 – Politica de Seguridad	Politica marco que rige los controles criptograficos
PS03 – Plan de Continuidad de Negocio	Procedimientos de emergencia ante compromiso de claves (seccion 6.3)
PS04 – Plan del SGSI	Seccion 9 contiene el resumen del ciclo de vida de claves; este documento lo expande
CPS (Declaracion de Practicas de Certificacion)	Secciones 4.5, 3.3, 5.7 describen generacion, re-emision y compromiso

2. Objetivo y Alcance

2.1 Objetivo

Establecer los procedimientos detallados para la administracion del ciclo de vida completo de las llaves criptograficas de Goya Ledger SpA en su calidad de Prestador de Servicios de Certificacion (PSC) bajo la Ley 19.799 y DS 181/2002. Este documento satisface el sub-proceso PS06 de la Guia de Acreditacion EA-103 v2.1, alineado con ETSI TS 102 042 seccion 7.2.

2.2 Alcance

Este plan cubre todas las llaves criptograficas generadas, almacenadas, utilizadas y destruidas por el PSC y sus suscriptores, incluyendo:

- Llaves de la Autoridad Certificadora (CA raiz e intermedia).
- Llaves de la Autoridad de Sellado de Tiempo (TSA).
- Llaves del Respondedor OCSP.
- Llaves del emisor OID4VCI.
- Llaves TLS de nodos de infraestructura.
- Llaves de consenso BFT.
- Llaves de suscriptores para Firma Electronica Simple (FES) y Avanzada (FEA).

2.3 Relacion con PS04 seccion 9

PS04 seccion 9 establece el inventario y las politicas generales del ciclo de vida de claves. Este documento extiende esa seccion con:

- Procedimientos operativos detallados para cada fase del ciclo de vida.
- Ceremonia de generacion de llave raiz CA con guion paso a paso.
- Requisitos de hardware criptografico (ETSI 7.2.7).
- Servicios de llaves para suscriptores (ETSI 7.2.8).
- Preparacion de dispositivos seguros (ETSI 7.2.9).

3. Marco Normativo

Norma	Aplicacion
Ley 19.799	Documentos electronicos, firma electronica y PSC
DS 181/2002	Reglamento de la Ley 19.799
EA-103 v2.1 seccion 4.13	Requisitos del sub-proceso PS06 para acreditacion
ETSI TS 102 042 seccion 7.2	Gestion de claves de CA: generacion, almacenamiento, respaldo, distribucion, uso, fin de vida, hardware, suscriptores, dispositivos
FIPS 140-2 / FIPS 140-3	Requisitos de modulos criptograficos (niveles de seguridad)
FIPS 204	ML-DSA (Module-Lattice-Based Digital Signature Algorithm)
FIPS 186-5	Estandar de firma digital (Ed25519, ECDSA P-256)
NIST SP 800-57 Parte 1 Rev. 5	Recomendaciones para gestion de claves: tipos, estados, crypto-periodos
NIST SP 800-88 Rev. 1	Directrices para sanitizacion de medios (zeroizacion)
NIST SP 800-133 Rev. 2	Recomendaciones para generacion de claves criptograficas
BSI TR-02102-1 (2024)	Recomendaciones de algoritmos criptograficos y longitudes de clave
ANSSI Avis PQC (2024)	Migracion a criptografia post-cuantica con modo hibrido obligatorio
ISO 27002:2022 Control 8.24	Uso de criptografia
RFC 3161	Protocolo de sellado de tiempo
RFC 6960	Protocolo OCSP

4. Inventario de Llaves Criptograficas

4.1 Tabla de inventario

ID	Tipo de llave	Algoritmo	Tamano clave publica	Tamano firma	Proposito	Nivel de proteccion	Crypto-periodo	R
K-01	CA raiz	ML-DSA-65 (FIPS 204, NIST Nivel 3)	1952 bytes	3309 bytes	Firma de certificado CA intermedia, firma de CRL raiz	Maxima (offline, M-of-N)	10 anos	AC R

ID	Tipo de llave	Algoritmo	Tamano clave publica	Tamano firma	Proposito	Nivel de proteccion	Crypto-periodo	RPS
K-02	CA intermedia	ML-DSA-65 (FIPS 204, NIST Nivel 3)	1952 bytes	3309 bytes	Firma de certificados FEA de suscriptores, firma de CRL	Critica (HSM objetivo)	3 anos	Alto
K-03	TSA	ML-DSA-65 (FIPS 204, NIST Nivel 3)	1952 bytes	3309 bytes	Firma de sellos de tiempo RFC 3161	Critica (HSM objetivo)	3 anos	Alto
K-04	OCSP	ML-DSA-65 (FIPS 204, NIST Nivel 3)	1952 bytes	3309 bytes	Firma de respuestas OCSP RFC 6960	Critica (HSM objetivo)	90 dias	Alto
K-05	TLS nodos	ECDSA P-256 (FIPS 186-5)	65 bytes (sin comprimir)	64 bytes	Autenticacion y cifrado TLS 1.3 entre nodos	Alta (volumen persistente Fly.io)	1 ano	Alto
K-06	OID4VCI emisor	ECDSA P-256 / ES256	65 bytes (sin comprimir)	64 bytes	Firma de tokens OAuth 2.0, emision de credenciales verificables	Alta (memoria volatil)	1 ano	Medio
K-07	Suscriptor FES	Ed25519 (FIPS 186-5)	32 bytes	64 bytes	Firma Electronica Simple	Media (dispositivo suscriptor)	2 anos	Alto
K-08	Suscriptor FEA	ML-DSA-65 (FIPS 204, NIST Nivel 3)	1952 bytes	3309 bytes	Firma Electronica Avanzada	Alta (dispositivo suscriptor)	3 anos	Alto
K-09	Consenso BFT	Ed25519 (FIPS 186-5)	32 bytes	64 bytes	Firma de votos y propuestas en protocolo HotStuff BFT	Alta (memoria volatil nodo)	1 ano	Alto

4.2 Parametros de seguridad

Algoritmo	Estandar	Seguridad clasica (bits)	Seguridad cuantica (bits)	Familia
ML-DSA-65	FIPS 204	192	143 (estimacion NIST)	Post-cuantico (lattice)

Algoritmo	Estandar	Seguridad clasica (bits)	Seguridad cuantica (bits)	Familia
Ed25519	FIPS 186-5	128	0 (vulnerable a Shor)	Clasico (curva eliptica)
ECDSA P-256 / ES256	FIPS 186-5	128	0 (vulnerable a Shor)	Clasico (curva eliptica)
SLH-DSA-128s	FIPS 205	128	64 (hash-based)	Post-cuantico (respaldo)

5. Estados y Crypto-periodos

5.1 Estados de llave (NIST SP 800-57)

Estado	Descripcion	Operaciones permitidas
Pre-activacion	Llave generada pero aun no autorizada para uso operativo	Ninguna operacion criptografica. Solo almacenamiento seguro
Activa	Llave autorizada para proteger informacion	Firma, verificacion, cifrado segun tipo
Desactivada	Crypto-periodo expirado o llave retirada del uso activo	Solo verificacion de firmas existentes, no generacion de nuevas
Comprometida	Compromiso confirmado o sospechado	Ninguna operacion. Revocacion inmediata del certificado asociado. Procedimiento PS03 seccion 6.3
Destruida	Llave eliminada de forma irreversible	Ninguna operacion. Material criptografico zeroizado

5.2 Crypto-periodos por tipo de llave

Basado en NIST SP 800-57 Parte 1 Rev. 5, Tabla 1 y recomendaciones ETSI TS 102 042.

ID	Tipo	Crypto-periodo activo	Periodo total de proteccion	Justificacion
K-01	CA raiz	10 anos	20 anos (verificacion)	Raiz PKI, uso excepcional. NIST recomienda hasta 20 anos para llaves de CA raiz

ID	Tipo	Crypto-periodo activo	Periodo total de proteccion	Justificacion
K-02	CA intermedia	3 anos	10 anos (verificacion)	Uso operativo frecuente. Rotacion cada 3 anos limita exposicion Alineado con CA intermedia.
K-03	TSA	3 anos	10 anos (verificacion)	Sellos de tiempo requieren verificacion a largo plazo Rotacion frecuente reduce impacto de compromiso.
K-04	OCSP	90 dias	1 ano (verificacion)	ETSI recomienda periodos cortos para OCSP
K-05	TLS nodos	1 ano	1 ano	Llave de transporte, sin requisito de verificacion posterior Tokens OAuth tienen vida corta, pero
K-06	OID4VCI emisor	1 ano	2 anos (verificacion)	credenciales verificables requieren verificacion posterior
K-07	Suscriptor FES	2 anos	5 anos (verificacion)	Firma simple, periodo estandar para certificados de usuario
K-08	Suscriptor FEA	3 anos	10 anos (verificacion)	Firma avanzada con valor legal, documentos deben ser

ID	Tipo	Crypto-periodo activo	Periodo total de proteccion	Justificacion
K-09	Consenso BFT	1 ano	1 ano	verificables a largo plazo Llave de autenticacion interna, sin verificacion posterior requerida

5.3 Transiciones de estado

Las transiciones validas entre estados son:

1. **Pre-activacion -> Activa:** Tras verificar la generacion correcta (firma de prueba exitosa) y aprobacion del Oficial de Seguridad.
2. **Activa -> Desactivada:** Al expirar el crypto-periodo o por decision operativa. La llave se retira de uso pero se conserva para verificacion.
3. **Activa -> Comprometida:** Ante compromiso confirmado o sospechado. Activacion del procedimiento PS03 seccion 6.3.
4. **Desactivada -> Destruida:** Cuando el periodo total de proteccion expira y no existen documentos pendientes de verificacion.
5. **Comprometida -> Destruida:** Tras completar el procedimiento de respuesta a incidentes y confirmar que la llave fue revocada.
6. **Pre-activacion -> Destruida:** Si la verificacion de generacion falla o la llave se descarta antes de activarse.

Transiciones no permitidas: Destruida a cualquier estado. Comprometida a Activa. Desactivada a Activa (se genera nueva llave).

6. Ciclo de Vida por Fase

6.1 Generacion de Llaves (ETSI TS 102 042 seccion 7.2.1)

6.1.1 Llave CA raiz (K-01)

La generacion de la llave CA raiz se ejecuta mediante ceremonia formal descrita en la seccion 10.

Requisitos:

- Algoritmo: ML-DSA-65 (FIPS 204), nivel de seguridad NIST 3.
- Equipo air-gapped sin conexion a red (ni WiFi, ni Ethernet, ni Bluetooth).
- Generador de numeros aleatorios: CSPRNG del sistema operativo (getrandom(2) en Linux), verificado por el modulo pqc_crypto_module.
- Entropia minima: 256 bits.
- Verificacion inmediata: generacion de firma de prueba sobre datos conocidos, verificacion con la clave publica resultante.

- La llave privada nunca se almacena completa en un solo medio. Se divide inmediatamente mediante Shamir Secret Sharing (3-of-5).
- Hash SHA-256 de la clave publica registrado en acta de ceremonia.

6.1.2 Llaves operativas (K-02, K-03, K-04, K-06)

- Algoritmo: ML-DSA-65 (K-02, K-03, K-04) o ECDSA P-256 (K-06).
- Generacion en el servidor del PSC mediante `pqc_crypto_module`. Todos los algoritmos de firma implementan el trait `SigningProvider` definido en `src/identity/signing.rs`.
- La enum `SigningAlgorithm` define los algoritmos validos: `Ed25519`, `MlDsa65`, `SlhDsa128s`, `Rsa`, `EcdsaP256`.
- CSPRNG del sistema operativo como fuente de entropia.
- Verificacion: firma y verificacion de prueba, registro en log de auditoria estructurado (JSON).
- Estado actual: generacion en memoria volatil con zeroize-on-drop.
- Estado objetivo: generacion dentro de HSM FIPS 140-3 Nivel 3 (2027-Q1).
- Participantes: Administrador PKI y Oficial de Seguridad (control dual).

6.1.3 Llaves TLS de nodos (K-05) y consenso BFT (K-09)

- Algoritmo: ECDSA P-256 (K-05), Ed25519 (K-09).
- Generacion automatica en cada nodo al momento del despliegue.
- K-05: certificado X.509 auto-firmado o emitido por CA intermedia para mTLS entre nodos.
- K-09: par de llaves Ed25519 generado por el nodo BFT al iniciar. Clave publica registrada en el conjunto de validadores.
- Entropia: CSPRNG del sistema operativo del contenedor Fly.io.

6.1.4 Llaves de suscriptores (K-07, K-08)

- Algoritmo FES: Ed25519 (K-07). FEA: ML-DSA-65 (K-08).
- Generacion exclusivamente en el dispositivo del suscriptor (app Tauri desktop, biblioteca cliente o wallet mobile).
- El PSC nunca genera, almacena ni accede a la llave privada del suscriptor.
- La posesion de la llave privada se verifica mediante el proceso de CSR (Certificate Signing Request).
- La aplicacion Tauri utiliza `pqc_crypto_module` para la generacion.
- El suscriptor es responsable del respaldo de su propia llave privada.

6.1.5 Fuentes de entropia

Entorno	Fuente primaria	Fuente secundaria	Verificacion
Servidor Linux (Fly.io)	<code>getrandom(2)</code> (CSPRNG kernel)	<code>/dev/urandom</code>	Test de entropia al inicio del proceso
Equipo air-gapped (ceremonia)	<code>getrandom(2)</code>	Hardware RNG (si disponible) <code>getrandom(2)</code>	Test NIST SP 800-22 sobre muestra de 1 MB

Entorno	Fuente primaria	Fuente secundaria	Verificacion
Dispositivo suscriptor (macOS/ Tauri)	SecRandomCopyBytes (Security.framework)		Verificacion automatica por pqc_crypto_module

6.1.6 Criterios de seleccion de algoritmo

Servicio	Algoritmo seleccionado	Justificacion
CA, TSA, OCSP, FEA	ML-DSA-65	Resistencia post-cuantica (NIST Nivel 3). Clasificado “recommended” por BSI TR-02102-1 (2024). Certificados de larga duracion requieren proteccion contra computacion cuantica futura
OID4VCI, TLS	ECDSA P-256 / ES256	Interoperabilidad con ecosistema OAuth 2.0 / OpenID4VCI. Clasificado “transitional” por BSI TR-02102-1. Tokens de vida corta no requieren proteccion post-cuantica
FES, BFT	Ed25519	Rendimiento y tamano compacto (32B pubkey, 64B firma). Clasificado “transitional” por BSI TR-02102-1. FES es firma simple sin valor legal equivalente a FEA. Consenso BFT prioriza throughput
Respaldo PQC	SLH-DSA-128s	Hash-based, independiente de supuestos lattice. Clasificado “recommended” por BSI TR-02102-1. Disponible como fallback si ML-DSA resulta vulnerable

La seleccion de algoritmos incorpora el requisito ANSSI de modo hibrido obligatorio (Avis PQC 2024, seccion 2): todo despliegue PQC combina una firma clasica (ECC) con una firma post-cuantica (lattice o hash), asegurando supuestos matematicos independientes. La seguridad no depende exclusivamente de ninguna familia criptografica.

6.2 Almacenamiento y Proteccion (ETSI TS 102 042 seccion 7.2.2)

6.2.1 Estado actual: almacenamiento basado en software

Llave	Almacenamiento actual	Proteccion	Zeroizacion
K-01 (CA raiz)	Fragmentos M-of-N en medios offline (USB cifrado o papel laminado)	Distribuido entre custodios, ubicaciones fisicas separadas	No aplica (fragmentos, no llave completa)
K-02 (CA intermedia)	Memoria volatil del proceso servidor	Aislamiento de proceso, ACL deny-by-default, TLS 1.3	zeroize trait al terminar el proceso
K-03 (TSA)	Memoria volatil del proceso servidor	Idem K-02	zeroize trait al terminar el proceso
K-04 (OCSP)	Memoria volatil del proceso servidor	Idem K-02	zeroize trait al terminar el proceso
K-05 (TLS nodos)	Volumen persistente cifrado Fly.io	Cifrado del volumen por la plataforma	Destruccion del volumen al dismantelar nodo
K-06 (OID4VCI)	Memoria volatil del proceso servidor	Idem K-02	zeroize trait al terminar el proceso
K-07, K-08 (suscriptores)	Dispositivo del suscriptor	Responsabilidad del suscriptor. App Tauri usa keychain del SO	N/A (fuera del control del PSC)
K-09 (consenso BFT)	Memoria volatil del nodo BFT	Aislamiento de proceso	zeroize trait al reiniciar nodo

6.2.2 Estado objetivo: HSM

Llave	Almacenamiento objetivo	Nivel FIPS 140-3	Plazo
K-01 (CA raiz)	Sin cambio (M-of-N offline ya es el objetivo)	N/A	Implementado
K-02 (CA intermedia)	HSM de red, clave no exportable	Nivel 3	2027-Q1

Llave	Almacenamiento objetivo	Nivel FIPS 140-3	Plazo
K-03 (TSA)	HSM de red, clave no exportable	Nivel 3	2027-Q1
K-04 (OCSP)	HSM de red, clave no exportable	Nivel 3	2027-Q1
K-06 (OID4VCI)	HSM o almacenamiento cifrado dedicado	Nivel 2 minimo	2027-Q2

6.2.3 Controles de acceso por tipo de llave

Llave	Quien puede usar	Quien puede administrar	Control de acceso
K-01	Nadie (offline)	Custodios M-of-N (presencia fisica de 3 de 5)	Ceremonia presencial con testigos
K-02	Proceso CA (automatico, via API interna)	Administrador PKI + Oficial de Seguridad (control dual)	ACL del sistema, autenticacion mutua
K-03	Proceso TSA (automatico)	Administrador PKI + Oficial de Seguridad	ACL del sistema
K-04	Proceso OCSP (automatico)	Administrador PKI	ACL del sistema
K-05	Proceso del nodo (automatico)	Administrador de Sistemas	Volumen cifrado, acceso SSH restringido
K-06	Proceso OID4VCI (automatico)	Administrador PKI	ACL del sistema
K-07, K-08	Suscriptor (exclusivo)	Suscriptor (exclusivo)	Credenciales del dispositivo
K-09	Proceso BFT del nodo (automatico)	Administrador de Sistemas	Aislamiento de proceso

6.3 Respaldo y Recuperacion (ETSI TS 102 042 seccion 7.2.3)

6.3.1 Respaldo de llave CA raiz (K-01) mediante M-of-N

Esquema: Shamir Secret Sharing, umbral 3-of-5.

Procedimiento de respaldo:

1. Durante la ceremonia de generacion (seccion 10), la llave privada CA raiz se divide en 5 fragmentos mediante Shamir Secret Sharing con umbral 3.
2. Cada fragmento se almacena en un medio independiente:
 - Opcion A: USB cifrado con AES-256 (LUKS o equivalente), protegido por frase de paso unica por custodio.
 - Opcion B: Papel laminado con el fragmento codificado en hexadecimal, sellado con tamper-evident bag.
3. Cada custodio recibe exactamente un fragmento y firma acta de custodia.

4. Los medios se almacenan en ubicaciones físicas independientes con control de acceso registrado (caja fuerte, bóveda bancaria o equivalente).
5. Ningún custodio puede poseer más de un fragmento.

Procedimiento de recuperación:

1. El Oficial de Seguridad convoca a los custodios (mínimo 3 de 5).
2. Se verifica la identidad de cada custodio mediante documento oficial.
3. Cada custodio ingresa su fragmento en un equipo air-gapped designado para la recuperación.
4. El software de recombinación Shamir reconstruye la llave privada en memoria volátil.
5. Se genera una firma de prueba sobre datos conocidos y se verifica con la clave pública CA raíz registrada.
6. Se ejecuta la operación requerida (firma de nuevo certificado CA intermedia, CRL, etc.).
7. Al finalizar, la llave reconstruida se zeroiza de memoria.
8. Se registra acta de recuperación firmada por todos los participantes.

Frecuencia de prueba: Simulacro anual de recombinación con fragmentos de prueba (no la llave real de producción).

6.3.2 Respaldo de llaves operativas (K-02, K-03, K-04)

Estado actual: Sin respaldo separado. Las llaves operativas se regeneran si se pierden, firmando nuevos certificados con la CA raíz (K-01) o CA intermedia (K-02).

Estado objetivo: Respaldo cifrado en HSM secundario o medio offline cifrado (AES-256). Plazo: 2027-Q1 (junto con migración a HSM).

Procedimiento de recuperación (actual):

1. Generar nueva llave ML-DSA-65 en el servidor.
2. Generar CSR y firmar con la CA de nivel superior.
3. Desplegar nuevo certificado.
4. Publicar CRL con el certificado anterior si corresponde.
5. Actualizar respondedor OCSP.
6. Registrar en log de auditoría.

6.3.3 Política de respaldo para llaves de suscriptores

El PSC no realiza respaldo de llaves privadas de suscriptores. El suscriptor es responsable de:

- Mantener su propia copia de seguridad de la llave privada.
- Si la llave se pierde, solicitar revocación del certificado asociado y emitir uno nuevo con nueva llave.

Esta política es deliberada: el PSC no debe tener la capacidad de firmar en nombre del suscriptor.

6.3.4 Calendario de pruebas de recuperacion

Llave	Prueba	Frecuencia	Responsable
K-01	Simulacro de recombinaion M-of-N	Anual	Oficial de Seguridad
K-02, K-03, K-04	Prueba de regeneracion de llave y firma de certificado	Semestral	Administrador PKI
K-05	Prueba de rotacion TLS	Trimestral	Administrador de Sistemas
K-09	Prueba de regeneracion de llave de nodo BFT	Semestral	Administrador de Sistemas

6.4 Distribucion (ETSI TS 102 042 seccion 7.2.4)

6.4.1 Mecanismos de transporte de llaves

Tipo de llave	Mecanismo de distribucion	Canal
K-01 (CA raiz publica)	Publicacion en repositorio del PSC, incluida en certificado CA raiz auto-firmado	HTTPS (repositorio publico)
K-02 (CA intermedia publica)	Incluida en certificado CA intermedia, firmado por CA raiz	HTTPS, descarga por suscriptores
K-03, K-04 (TSA/OCSP publicas)	Incluidas en sus respectivos certificados	HTTPS
K-06 (OID4VCI publica)	Publicacion via JWKS endpoint (/ .well-known/jwks . json) conforme a RFC 7517	HTTPS
K-07, K-08 (suscriptor publica)	Incluida en CSR (suscriptor -> PSC), luego en certificado X.509 emitido (PSC -> suscriptor)	TLS 1.3 (API del PSC)
K-09 (BFT publica)	Registro en conjunto de validadores, intercambio via protocolo P2P con mTLS	mTLS entre nodos

Llaves privadas nunca se transmiten por red. K-01 se distribuye fisicamente como fragmentos M-of-N. K-02 a K-09 se generan en el sistema donde se usan.

6.4.2 Politica de custodia (key escrow)

- **Llaves del PSC (K-01 a K-06, K-09):** No se depositan en custodia de terceros. La unica forma de respaldo es M-of-N (K-01) o regeneracion (K-02 a K-06, K-09).
- **Llaves de suscriptores (K-07, K-08):** No se depositan en custodia. El PSC no tiene acceso a llaves privadas de suscriptores.

6.4.3 Distribucion de claves publicas

Formato	Estandar	Uso
Certificado X.509 v3	RFC 5280	CA, TSA, OCSP, suscriptores
JWKS (JSON Web Key Set)	RFC 7517	OID4VCI emisor
DID Document	did:goya:{pubkey_hex[..16]}	Identidad descentralizada en blockchain

6.5 Uso de Llaves (ETSI TS 102 042 seccion 7.2.5)

6.5.1 Operaciones autorizadas por tipo de llave

Llave	Operaciones autorizadas	Operaciones prohibidas
K-01 (CA raiz)	Firma de certificado CA intermedia, firma de CRL raiz	Firma directa de certificados de suscriptor, cifrado, cualquier operacion online
K-02 (CA intermedia)	Firma de certificados FEA de suscriptores, firma de CRL intermedia	Cifrado, firma de sellos de tiempo
K-03 (TSA)	Firma de sellos de tiempo RFC 3161	Firma de certificados, cifrado
K-04 (OCSP)	Firma de respuestas OCSP	Firma de certificados, firma de sellos de tiempo
K-05 (TLS)	Autenticacion TLS 1.3 (handshake ECDHE)	Firma de documentos, firma de certificados
K-06 (OID4VCI)	Firma de tokens JWT para emision de credenciales verificables	Firma de certificados X.509
K-07 (FES)	Firma Electronica Simple (documentos, transacciones)	Firma de certificados, uso como FEA
K-08 (FEA)	Firma Electronica Avanzada (documentos legales)	Firma de certificados
K-09 (BFT)	Firma de votos, propuestas y bloques en protocolo HotStuff	Cualquier operacion fuera del consenso

6.5.2 Control dual y conocimiento dividido

Operacion	Requisito de control dual	Participantes
Activacion de K-01 (recombinacion M-of-N)	3 de 5 custodios presentes	Custodios de fragmentos + Oficial de Seguridad
Generacion de K-02, K-03, K-04	Dos personas	Administrador PKI + Oficial de Seguridad
Revocacion de certificado CA intermedia	Dos personas	Oficial de Seguridad + Gerencia General
Cambio de politica de algoritmo	Dos personas	Arquitecto Criptografico + Oficial de Seguridad

Operaciones que no requieren control dual: firma automatica de certificados de suscriptor (K-02), firma de sellos de tiempo (K-03), firma de respuestas OCSP (K-04). Estas operaciones son automatizadas y su autorizacion se controla via ACL del sistema.

6.5.3 Registro y monitoreo de uso

Todas las operaciones criptograficas se registran en el log de auditoria estructurado (JSON) con los siguientes campos:

Campo	Descripcion
timestamp	Marca de tiempo ISO 8601 con zona horaria
key_id	Identificador de la llave utilizada (K-01 a K-09)
operation	Operacion realizada (sign, verify, activate, deactivate, destroy)
algorithm	Algoritmo utilizado (como lo reporta <code>SigningAlgorithm::fmt()</code>)
subject	Sujeto de la operacion (DN del certificado, hash del documento)
operator	Identidad del operador o proceso automatico
result	Exito o fallo con detalle
trace_id	ID de traza para correlacion con otros logs

Los logs se almacenan en la cadena hash append-only de RocksDB (activo AD-01 de PS01). Retencion minima: 10 anos conforme a Ley 19.799.

Alertas automaticas: firma con llave fuera de crypto-periodo, intento de uso de llave revocada, error de verificacion, acceso denegado a llave.

6.6 Fin de Vida y Destruccion (ETSI TS 102 042 seccion 7.2.6)

6.6.1 Procedimientos de zeroizacion

Tipo de medio	Metodo de zeroizacion	Referencia
Memoria volatil (RAM)	Sobrescritura con ceros via zeroize trait de Rust, verificado por test unitario	NIST SP 800-88, pqc_crypto_module
USB cifrado (fragmentos M-of-N)	Borrado criptografico (destruccion de llave de cifrado LUKS) + sobrescritura completa del dispositivo	NIST SP 800-88 purge
Papel laminado (fragmentos M-of-N)	Destruccion fisica: trituracion cross-cut (particula $\leq 2\text{mm} \times 15\text{mm}$, nivel P-5 DIN 66399) o incineracion	NIST SP 800-88 destroy
Volumen persistente Fly.io	Eliminacion del volumen mediante API de Fly.io + solicitud de zeroizacion al proveedor	Politica de Fly.io
HSM (futuro)	Zeroizacion interna del HSM mediante comando de fabrica	FIPS 140-3, manual del fabricante

6.6.2 Requisitos previos a la destruccion

Antes de destruir cualquier llave, se debe verificar:

1. Que la llave esta en estado Desactivada o Comprometida.
2. Que el certificado asociado ha sido revocado (si aplica).
3. Que la CRL con la revocacion ha sido publicada.
4. Que no existen documentos firmados pendientes de verificacion que dependan exclusivamente de esta llave.
5. Que el Oficial de Seguridad ha autorizado la destruccion.
6. Que el hash de la clave publica esta registrado en el log de auditoria para trazabilidad.

6.6.3 Archivado previo a la destruccion

Dato a archivar	Formato	Periodo de retencion	Ubicacion
Clave publica	X.509 (DER)	20 anos	Repositorio publico del PSC, blockchain
Hash SHA-256 de clave publica	Hexadecimal	20 anos	Log de auditoria (RocksDB)
Certificado asociado	X.509 (DER)	20 anos	Repositorio publico del PSC

Dato a archivar	Formato	Periodo de retencion	Ubicacion
Fecha y hora de destruccion	ISO 8601	20 anos	Log de auditoria
Acta de destruccion	PDF firmado digitalmente	20 anos	Archivo documental del PSC

6.6.4 Verificacion de destruccion

- Para llaves en memoria: verificacion automatica por test unitario del trait zeroize.
- Para medios fisicos: acta de destruccion firmada por dos personas (Oficial de Seguridad + testigo).
- Para HSM (futuro): confirmacion del HSM que la llave fue eliminada + log de auditoria del HSM.

7. Ciclo de Vida del Hardware Criptografico (ETSI TS 102 042 seccion 7.2.7)

7.1 Estado actual

Al momento de redaccion de este documento, el PSC opera con almacenamiento de llaves basado en software. Las llaves privadas operativas (K-02, K-03, K-04, K-06) residen en la memoria volatil del proceso servidor con zeroizacion al terminar, implementada mediante el trait zeroize del crate zeroize de Rust.

Esta configuracion es transitoria. El plan de migracion a HSM se detalla a continuacion.

7.2 Requisitos del HSM objetivo

Requisito	Especificacion
Certificacion	FIPS 140-3 Nivel 3 (minimo Nivel 2 para K-06)
Algoritmos soportados	ML-DSA-65 (FIPS 204), ECDSA P-256, Ed25519
Interfaz	PKCS#11 v2.40 o superior
Capacidad de llaves	Minimo 10 llaves asimetricas simultaneas
Rendimiento de firma	>= 100 firmas/segundo (ML-DSA-65)
Tamper evidence / tamper resistance	Nivel 3: deteccion y respuesta a intento de acceso fisico
Generacion de entropia interna	TRNG certificado
Auditoria	Log interno de operaciones accesible via API
Soporte de llaves no exportables	

Requisito	Especificacion
	Las llaves CA (K-02), TSA (K-03) y OSCP (K-04) deben ser no exportables

7.3 Adquisicion y puesta en marcha

Fase	Actividad	Responsable	Plazo
1. Evaluacion	Seleccion de proveedor y modelo HSM que cumpla requisitos de 7.2	Arquitecto Criptografico	2026-Q4
2. Adquisicion	Compra y recepcion en custodia del Oficial de Seguridad	Gerencia General	2026-Q4
3. Verificacion	Validacion de certificacion FIPS 140-3, verificacion de integridad de firmware, prueba de algoritmos ML-DSA-65	Arquitecto Criptografico + Oficial de Seguridad	2027-Q1
4. Inicializacion	Configuracion de roles de acceso (Security Officer, Crypto User), generacion de PIN/ claves de administracion, particionamiento	Administrador PKI + Oficial de Seguridad (control dual)	2027-Q1
5. Generacion de llaves	Generacion de K-02, K-03, K-04 dentro del HSM como llaves no exportables	Administrador PKI + Oficial de Seguridad (control dual)	2027-Q1
6. Migracion	Emision de nuevos certificados firmados con CA raiz, transicion gradual desde llaves en software	Administrador PKI	2027-Q1
7. Operacion	Produccion con monitoreo continuo de salud y rendimiento del HSM	Administrador de Sistemas	2027-Q1 en adelante

7.4 Actualizacion de firmware

- Las actualizaciones de firmware del HSM deben ser provistas por el fabricante y verificadas con firma digital del fabricante.

- Antes de aplicar cualquier actualizacion, se debe realizar un respaldo de la configuracion del HSM.
- La actualizacion se ejecuta en horario de mantenimiento con control dual (Administrador PKI + Oficial de Seguridad).
- Tras la actualizacion se verifica la integridad de todas las llaves almacenadas mediante firma de prueba.
- Se registra la version de firmware anterior y nueva en el log de auditoria.

7.5 Desmantelamiento y disposicion

Al fin de vida del HSM:

1. Extraer o migrar todas las llaves a un HSM de reemplazo (si las llaves son exportables bajo wrapping key).
2. Si las llaves no son exportables, generar nuevas llaves en el HSM de reemplazo y emitir nuevos certificados.
3. Ejecutar zeroizacion completa del HSM mediante comando de fabrica.
4. Verificar que el HSM reporta estado “no inicializado” tras la zeroizacion.
5. Registrar acta de desmantelamiento firmada por Oficial de Seguridad.
6. Disposicion fisica: devolucion al fabricante para destruccion certificada, o destruccion fisica documentada.

8. Servicios de Llaves para Suscriptores (ETSI TS 102 042 seccion 7.2.8)

8.1 Generacion de llaves de suscriptores

Las llaves de suscriptores se generan exclusivamente en el dispositivo del suscriptor. El PSC provee las herramientas para la generacion:

Herramienta	Algoritmo	Uso
App Tauri desktop	ML-DSA-65 (FEA), Ed25519 (FES)	Generacion de par de llaves y CSR. Almacenamiento en keychain del SO
Biblioteca cliente (pqc_crypto_module)	ML-DSA-65, Ed25519	Integracion para desarrolladores

Proceso de generacion por el suscriptor:

1. El suscriptor abre la aplicacion Tauri o utiliza la biblioteca cliente.
2. La aplicacion genera un par de llaves usando `pqc_crypto_module` con entropia del SO.
3. La llave privada se almacena en el keychain del sistema operativo (macOS Keychain, libsecret en Linux).
4. La aplicacion genera un CSR (Certificate Signing Request) que contiene la clave publica y esta firmado con la clave privada.

5. El CSR se envia al PSC via API REST (HTTPS).
6. El PSC verifica la firma del CSR para confirmar posesion de la llave privada.
7. El PSC emite el certificado X.509 firmado con K-02 (CA intermedia).
8. El certificado se entrega al suscriptor via API REST.

8.2 Renovacion de llaves de suscriptores

Cuando el certificado del suscriptor esta proximo a expirar (30 dias antes del fin del crypto-periodo), el PSC notifica al suscriptor. El proceso de renovacion es:

1. El suscriptor genera un nuevo par de llaves en su dispositivo.
2. El suscriptor genera un nuevo CSR con la nueva clave publica.
3. El suscriptor autentica la solicitud de renovacion con su certificado vigente (firma del CSR con la llave anterior como prueba de continuidad).
4. El PSC verifica la firma del CSR con la nueva clave y la firma de continuidad con la clave anterior.
5. El PSC emite un nuevo certificado.
6. El certificado anterior se mantiene activo hasta su expiracion natural, salvo revocacion.

8.3 Recuperacion de llaves de suscriptores

El PSC no soporta recuperacion de llaves privadas de suscriptores. Esta decision es por diseno:

- El PSC nunca posee ni almacena la llave privada del suscriptor.
- No existe mecanismo de key escrow para suscriptores.
- Si el suscriptor pierde su llave privada, debe revocar el certificado asociado y generar una nueva llave con un nuevo certificado.
- Los documentos firmados con la llave perdida siguen siendo verificables con el certificado publico archivado.

9. Preparacion de Dispositivos Seguros (ETSI TS 102 042 seccion 7.2.9)

9.1 App Tauri desktop (light client)

Aspecto	Implementacion actual	Objetivo
Almacenamiento de llave privada	macOS Keychain (kSecAttrAccessibleWhenUnlocked)	Idem + soporte para Secure Enclave (Apple T2/M1+)
Proteccion de acceso	Autenticacion del usuario al SO (biometria o contraseña)	Idem + PIN dedicado de la aplicacion
Generacion de llaves	pqc_crypto_module con entropia del SO	Idem (ya cumple requisitos)
Cifrado de datos locales	Datos de identidad DID como JSON en GOYA_DATA_DIR (~/.goya/)	Cifrado AES-256-GCM derivado de

Aspecto	Implementacion actual	Objetivo
Nivel FIPS 140-2 actual	No certificado (software puro)	llave maestra del usuario FIPS 140-2 Nivel 1 (validacion del modulo pqc_crypto_module)

9.2 Wallet mobile (futuro)

Aspecto	Objetivo
Almacenamiento de llave privada	Android Keystore (hardware-backed) / iOS Secure Enclave
Nivel de proteccion	FIPS 140-2 Nivel 3 (hardware) o CC EAL 3 (Common Criteria)
Autenticacion de acceso	Biometria (huella, rostro) + PIN
Generacion de llaves	Dentro del elemento seguro del dispositivo

9.3 Hoja de ruta de cumplimiento FIPS 140-2 Nivel 3 / CC EAL 3

EA-103 v2.1 requiere que los dispositivos de usuario cumplan FIPS 140-2 Nivel 3 o CC EAL 3 para operaciones de firma avanzada (FEA).

Hito	Descripcion	Plazo
1	Validacion FIPS 140-2 Nivel 1 del modulo pqc_crypto_module (software)	2027-Q2
2	Integracion con Secure Enclave (Apple) y Android Keystore (hardware-backed) para alcanzar Nivel 3 de facto	2027-Q3
3	Evaluacion CC EAL 3 del modulo de firma de la app Tauri	2027-Q4
4	Soporte de tokens USB criptograficos (PKCS#11) como alternativa	2028-Q1

10. Ceremonia de Generacion de Llave Raiz CA

10.1 Participantes y roles

Rol	Responsabilidad	Cantidad minima
Administrador de Ceremonia	Dirige la ceremonia, ejecuta los comandos, toma decisiones operativas	1

Rol	Responsabilidad	Cantidad minima
de Claves (ACC)		
Oficial Criptografico (OC)	Verifica cada paso criptografico, valida parametros del algoritmo	1
Testigo	Observa y atestigua la ejecucion correcta de cada paso	1 (minimo, recomendado 2)
Escribano	Documenta cada paso con hora exacta, registra desvios	1
Custodios de fragmentos	Reciben y custodian los fragmentos M-of-N	5

Ningun participante puede desempenar mas de un rol, excepto que un custodio puede ser tambien testigo.

10.2 Equipamiento requerido

Item	Especificacion	Verificacion previa
Equipo air-gapped	PC o laptop dedicado, sin WiFi/Bluetooth/Ethernet, disco formateado	Inspeccion visual de puertos (cinta sobre conectores de red). Verificacion de BIOS: wireless deshabilitado
Medio de arranque	USB booteable con Linux live (ej. Tails o Ubuntu minimal) con pqc_crypto_module precompilado	Hash SHA-256 del medio verificado contra valor publicado
USBs cifrados para fragmentos	5 unidades USB nuevas, selladas, con soporte LUKS	Verificar sello de fabrica intacto
Papel para fragmentos (alternativa)	Papel acid-free, bolsas tamper-evident	Verificar sellado
Impresora (si se usa papel)	Impresora sin memoria/ WiFi, conectada por USB al equipo air-gapped	Desconectar inmediatamente despues de imprimir
Reloj sincronizado	Reloj calibrado contra fuente NTP verificada antes de desconectar el equipo de la red	Registrar hora UTC al inicio
Camara de video	Para grabacion de la ceremonia completa	Verificar almacenamiento suficiente
Formularios impresos	Actas de ceremonia, custodia, destruccion de testigos	Preparar antes de la ceremonia

10.3 Seguridad de la sala

1. Sala cerrada con control de acceso (llave fisica o tarjeta). Solo los participantes listados pueden estar presentes.
2. Sin ventanas exteriores o con persianas cerradas.
3. Sin dispositivos electronicos personales (telefonos moviles, smartwatches, laptops) dentro de la sala. Se depositan en una caja sellada en la entrada.
4. Camara de seguridad de la sala activada (si existe) o camara de video portatil operada por el Escribano.
5. Verificacion de que no hay dispositivos de escucha o grabacion no autorizados.
6. La puerta permanece cerrada durante toda la ceremonia. Las salidas y entradas se registran con hora.

10.4 Guion de la ceremonia

Fase 0: Pre-ceremonia (dia anterior)

☐

ACC verifica la disponibilidad de los 5 custodios para el dia de la ceremonia.

☐

ACC prepara el equipo air-gapped: formatear disco, instalar SO desde medio verificado.

☐

ACC compila `pqc_crypto_module` en un equipo conectado, copia el binario al medio de arranque, verifica hash SHA-256.

☐

ACC prepara los 5 USBs cifrados (inicializar LUKS con frase de paso temporal).

☐

ACC prepara los formularios de acta de ceremonia y acta de custodia (5 copias).

☐

ACC verifica la camara de video y el almacenamiento.

☐

ACC notifica a todos los participantes la hora y ubicacion.

Fase 1: Apertura (15 minutos)

☐

10:00 – ACC abre la sala y verifica seguridad (sin dispositivos no autorizados, puerta asegurada).

☐

Cada participante ingresa, registra su nombre y rol en el acta de ceremonia, y deposita dispositivos electronicos personales.

☐

ACC verifica la identidad de cada participante con documento oficial.

☐

Escribano inicia la grabacion de video.

☐

ACC lee en voz alta el proposito de la ceremonia y los roles asignados.

☐

Todos los participantes confirman verbalmente que comprenden su rol.

Fase 2: Preparacion del equipo (15 minutos)

☐

ACC arranca el equipo air-gapped desde el medio USB bootable.

☐

OC verifica que no hay conexion de red activa: `ip link show` (solo lo debe estar UP), `rfkill list` (todo bloqueado).

☐

OC verifica la version de `ppc_crypto_module`: `./ppc_crypto_module --version`.

☐

OC ejecuta test de entropia: `./ppc_crypto_module entropy-test --samples 1048576` (debe pasar tests NIST SP 800-22).

☐

Escribano registra los resultados del test de entropia en el acta.

☐

Si el test de entropia falla, la ceremonia se suspende. ACC investiga y reprograma.

Fase 3: Generacion de llave (10 minutos)

☐

ACC ejecuta el comando de generacion: `./ppc_crypto_module keygen --algorithm ml-dsa-65 --output /tmp/ca-root`.

☐

El comando genera: `/tmp/ca-root.sk` (llave privada, 4032 bytes) y `/tmp/ca-root.pk` (llave publica, 1952 bytes).

☐

OC verifica el tamano de los archivos: `wc -c /tmp/ca-root.sk /tmp/ca-root.pk`.

☐

ACC ejecuta firma de prueba: `./ppc_crypto_module sign --key /tmp/ca-root.sk --data "GOYA LEDGER CA ROOT KEY CEREMONY" --output /tmp/test.sig`.

☐

OC ejecuta verificacion: `./ppc_crypto_module verify --key /tmp/ca-root.pk --data "GOYA LEDGER CA ROOT KEY CEREMONY" --signature /tmp/test.sig`. Debe reportar "Verification: OK".

☐

Si la verificacion falla, la ceremonia se suspende. Se destruye el material generado y se reprograma.

☐

ACC calcula el hash de la clave publica: `sha256sum /tmp/ca-root.pk`.
Escribano registra el hash en el acta.

☐

OC verifica independientemente el hash: `sha256sum /tmp/ca-root.pk`.
Ambos valores deben coincidir.

Fase 4: Division mediante Shamir Secret Sharing (15 minutos)

☐

ACC ejecuta la division: `./pqc_crypto_module shamir-split --key /tmp/ca-root.sk --threshold 3 --shares 5 --output /tmp/shares/`.

☐

El comando genera 5 archivos: `share-1.bin` a `share-5.bin`.

☐

OC verifica que existen exactamente 5 archivos: `ls -la /tmp/shares/`.

☐

ACC ejecuta verificacion de recombinacion con los 5 fragmentos: `./pqc_crypto_module shamir-combine --shares /tmp/shares/share-1.bin,/tmp/shares/share-2.bin,/tmp/shares/share-3.bin --output /tmp/recovered.sk`.

☐

OC compara la llave recuperada con la original: `sha256sum /tmp/ca-root.sk /tmp/recovered.sk`. Los hashes deben coincidir.

☐

ACC ejecuta segunda verificacion con un subconjunto diferente (fragmentos 2, 4, 5): `./pqc_crypto_module shamir-combine --shares /tmp/shares/share-2.bin,/tmp/shares/share-4.bin,/tmp/shares/share-5.bin --output /tmp/recovered2.sk`.

☐

OC compara: `sha256sum /tmp/ca-root.sk /tmp/recovered2.sk`. Los hashes deben coincidir.

☐

Escribano registra ambas verificaciones exitosas en el acta.

Fase 5: Firma del certificado raiz (10 minutos)

☐

ACC genera el certificado CA raiz auto-firmado: `./pqc_crypto_module cert-gen --key /tmp/ca-root.sk --pubkey /tmp/ca-root.pk --subject "CN=Goya Ledger Root CA,O=Goya Ledger SpA,C=CL" --validity-years 10 --output /tmp/ca-root.crt`.

☐

OC verifica el certificado: `./pqc_crypto_module cert-verify --cert /tmp/ca-root.crt --pubkey /tmp/ca-root.pk`. Debe reportar "Certificate: Valid".

☐

OC verifica los campos del certificado: subject, issuer (auto-firmado), validity, algorithm (ML-DSA-65), key usage (keyCertSign, cRLSign).

☐

Escribano registra el numero de serie del certificado y su huella digital SHA-256 en el acta.

Fase 6: Distribucion de fragmentos a custodios (15 minutos)

☐

ACC copia cada fragmento al USB cifrado correspondiente:

- share-1.bin -> USB #1, share-2.bin -> USB #2, ... share-5.bin -> USB #5.
- Cada USB se cifra con LUKS y una frase de paso unica elegida por el custodio (no compartida con nadie mas).

☐

Cada custodio verifica que puede montar y leer su USB con su frase de paso.

☐

Cada custodio firma el acta de custodia que incluye:

- Numero de fragmento asignado (1-5).
- Hash SHA-256 del archivo del fragmento.
- Compromiso de custodia y confidencialidad.
- Ubicacion de almacenamiento designada.

☐

Si se usa papel como alternativa o respaldo: imprimir el fragmento en hexadecimal, sellar en bolsa tamper-evident.

☐

Escribano registra el numero de fragmento y el custodio asignado (sin registrar el contenido del fragmento).

Fase 7: Exportacion de material publico (5 minutos)

☐

ACC copia al USB de exportacion (un USB adicional, no cifrado): /tmp/ca-root.pk y /tmp/ca-root.crt.

☐

OC verifica el contenido del USB de exportacion: solo contiene la clave publica y el certificado. No contiene la clave privada ni fragmentos.

☐

Escribano registra el hash SHA-256 de los archivos exportados.

Fase 8: Destruccion de material sensible (10 minutos)

☐

ACC zeroiza la llave privada original:

`shred -n 7 -z /tmp/ca-root.sk && rm /tmp/ca-root.sk.`

☐

ACC zeroiza las llaves recuperadas: `shred -n 7 -z /tmp/recovered.sk /tmp/recovered2.sk && rm /tmp/recovered.sk /tmp/recovered2.sk.`

☐

ACC zeroiza los fragmentos del directorio temporal: `shred -n 7 -z /tmp/shares/* && rm -rf /tmp/shares/.`

☐

ACC zeroiza la firma de prueba: `shred -n 7 -z /tmp/test.sig && rm /tmp/test.sig.`

☐

OC verifica que no queda material sensible en /tmp/: ls -la /tmp/ (solo deben quedar ca-root.pk y ca-root.crt si no se han exportado aun).

☐

ACC apaga el equipo air-gapped.

☐

ACC retira el medio de arranque USB y lo almacena en custodia del Oficial de Seguridad.

☐

Escribano registra la hora de destruccion.

Fase 9: Cierre (10 minutos)

☐

ACC lee en voz alta un resumen de la ceremonia.

☐

Todos los participantes firman el acta de ceremonia.

☐

Escribano detiene la grabacion de video.

☐

Cada custodio abandona la sala con su USB cifrado y se dirige a su ubicacion de almacenamiento designada.

☐

ACC confirma que la sala esta limpia de material criptografico.

☐

Los participantes recuperan sus dispositivos electronicos personales.

☐

ACC cierra la sala.

10.5 Post-ceremonia

1. **Dentro de 24 horas:** Escribano entrega el acta firmada y la grabacion de video al Oficial de Seguridad para archivo.
2. **Dentro de 48 horas:** ACC publica la clave publica CA raiz y el certificado en el repositorio publico del PSC.
3. **Dentro de 48 horas:** Cada custodio confirma por escrito que su fragmento esta almacenado en la ubicacion designada.
4. **Dentro de 7 dias:** ACC genera la CA intermedia (K-02) firmada con la CA raiz. Este proceso requiere recombinacion M-of-N (repetir fases 1-2, usar K-01 para firmar, luego destruir K-01 recombinada).

10.6 Frecuencia

- **Ceremonia inicial:** Una vez, al inicio de operaciones del PSC.
 - **Re-generacion de emergencia:** Ante compromiso de K-01, siguiendo procedimiento PS03 seccion 6.3.
 - **Renovacion programada:** Cada 10 anos (crypto-periodo de K-01), o antes si lo requiere un cambio de algoritmo.
-

11. Coherencia con CPS

Seccion CPS	Tema	Seccion PS06 correspondiente	Coherencia
4.5	Generacion de par de llaves	6.1 (Generacion de Llaves)	CPS define la politica; PS06 detalla el procedimiento operativo y la ceremonia (seccion 10)
3.3	Renovacion de certificados y re-emision de llaves	8.2 (Renovacion de llaves de suscriptores), 5.2 (Crypto-periodos)	CPS define periodos de validez; PS06 detalla el proceso de rotacion y renovacion
5.7	Procedimiento ante compromiso de llave	6.6 (Fin de Vida), 5.1 (Estado Comprometida)	CPS define la politica de revocacion; PS06 detalla la zeroizacion y destruccion. PS03 seccion 6.3 contiene el procedimiento de emergencia
4.7	Emision de certificados	6.5.1 (Operaciones autorizadas K-02)	CPS define los requisitos de emision; PS06 asegura que solo K-02 puede firmar certificados de suscriptor
6.1.5	Tamano de llaves	4.1 (Inventario), 4.2 (Parametros de seguridad)	CPS especifica tamanos minimos; PS06 documenta tamanos exactos por algoritmo
6.2.5	Proteccion de llave privada CA	6.2 (Almacenamiento), 10 (Ceremonia)	CPS requiere proteccion de nivel maximo;

Seccion CPS	Tema	Seccion PS06 correspondiente	Coherencia
			PS06 detalla M-of-N offline y HSM objetivo

12. Coherencia con PS01

ID Riesgo PS01	Descripcion del riesgo	Activo afectado	Control PS06	Nivel residual alcanzado
R-01	Robo de clave privada CA raiz (AE-03)	AC-01	M-of-N Shamir (3-of-5), almacenamiento offline distribuido, ceremonia con control dual (seccion 10), zeroizacion inmediata tras uso (seccion 10, fase 8)	Bajo
R-02	Robo de clave privada CA intermedia (AE-03)	AC-02	Memoria volatil con zeroize-on-drop (actual), HSM no exportable (objetivo 2027-Q1), ACL deny-by-default, control dual para generacion (seccion 6.1.2)	Medio (sera Bajo con HSM)
R-05	Emision no autorizada por administrador (AI-01)	AC-02, AD-03	Control dual para generacion de llaves (seccion 6.5.2), log de auditoria de todas las operaciones de firma (seccion 6.5.3), separacion de roles	Medio
QC-01	Vulnerabilidad de Ed25519 a computacion cuantica	AC-05	ML-DSA-65 disponible para FEA (K-08), migracion de FES a PQC planificada. SLH-DSA-128s como respaldo independiente de lattice (seccion 4.2)	Medio

ID Riesgo PS01	Descripcion del riesgo	Activo afectado	Control PS06	Nivel residual alcanzado
QC-03	Fallo durante transicion criptografica	AC-02, AC-03	Soporte simultaneo de multiples algoritmos via enum SigningAlgorithm en src/identity/signing.rs, periodos de transicion con llaves activas en paralelo	Medio

13. Revision y Mantencion

13.1 Revision periodica

Actividad	Frecuencia	Responsable
Revision completa del plan PS06	Anual	Oficial de Seguridad + Arquitecto Criptografico
Verificacion de crypto-periodos y estados de llaves	Trimestral	Administrador PKI
Simulacro de recombinacion M-of-N	Anual	Oficial de Seguridad
Revision de inventario de custodios y fragmentos	Semestral	Oficial de Seguridad
Auditoria independiente de gestion de claves	Anual (ETSI TS 102 042 mandatorio)	Auditor externo acreditado

13.2 Eventos que disparan revision extraordinaria

- Compromiso confirmado o sospechado de cualquier llave.
- Publicacion de nueva vulnerabilidad que afecte a ML-DSA-65, Ed25519 o ECDSA P-256.
- Cambio de normativa (Ley 19.799, DS 181, ETSI TS 102 042, FIPS 140).
- Adquisicion o puesta en marcha de HSM.
- Incorporacion de nuevo tipo de llave o algoritmo.
- Resultado de auditoria externa con hallazgos sobre gestion de claves.
- Cambio de personal en roles de custodio, Oficial de Seguridad o Administrador PKI.

13.3 Registro de revisiones

Cada revision se documenta con:

- Fecha de revision y participantes.
- Cambios realizados al documento (tabla de control de versiones, seccion 1).
- Hallazgos de la revision y acciones correctivas.
- Firma del Oficial de Seguridad y aprobacion de Gerencia General.

14. Referencias

Referencia	Titulo
Ley 19.799	Sobre documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002	Reglamento de la Ley 19.799
EA-103 v2.1	Guia de Acreditacion de Prestadores de Servicios de Certificacion
ETSI TS 102 042	Policy requirements for certification authorities issuing public key certificates
FIPS 140-2	Security Requirements for Cryptographic Modules
FIPS 140-3	Security Requirements for Cryptographic Modules (reemplaza FIPS 140-2)
FIPS 186-5	Digital Signature Standard (DSS)
FIPS 204	Module-Lattice-Based Digital Signature Algorithm (ML-DSA)
FIPS 205	Stateless Hash-Based Digital Signature Algorithm (SLH-DSA)
NIST SP 800-57 Parte 1 Rev. 5	Recommendation for Key Management: Part 1 - General
NIST SP 800-88 Rev. 1	Guidelines for Media Sanitization
NIST SP 800-133 Rev. 2	Recommendation for Cryptographic Key Generation
ISO/IEC 27001:2022	Information security management systems
ISO/IEC 27002:2022	Information security controls (Control 8.24: Use of cryptography)

Referencia	Titulo
RFC 3161	Internet X.509 PKI Time-Stamp Protocol (TSP)
RFC 5280	Internet X.509 PKI Certificate and CRL Profile
RFC 6960	X.509 Internet PKI Online Certificate Status Protocol - OCSP
RFC 7517	JSON Web Key (JWK)
BSI TR-02102-1 (2024)	Kryptographische Verfahren: Empfehlungen und Schlüssellängen
ANSSI Avis PQC (2024)	Avis relatif a la migration vers la cryptographie post-quantique
DIN 66399	Office machines - Destruction of data carriers
PS01	GOYA-PS01-001 - Plan de Gestion de Riesgos y Amenazas
PS02	GOYA-PS02-001 - Politica de Seguridad
PS03	GOYA-PS03-001 - Plan de Continuidad de Negocio
PS04	GOYA-PS04-001 - Plan del Sistema de Gestion de Seguridad de la Informacion
CPS	Declaracion de Practicas de Certificacion de Goya Ledger SpA